

# Information Security Policy

## Enterprise Security Governance

Prepared by: Office of the CISO

Baseline: NIST SP 800-53 Rev. 5 -- Moderate

Classification: Controlled Unclassified Information (CUI)

Status: Draft for pre-adjudication review

### 1. Purpose and Authority

This Information Security Policy establishes the enterprise requirements that govern the protection of information systems and the data they process. It is issued under the authority of the Chief Information Security Officer and applies to all personnel, contractors, and systems operating within the enterprise.

### 2. Scope

The policy applies to all information systems regardless of hosting model, and to all individuals granted access to those systems. Where a system-specific document and this policy both address a requirement, the more stringent provision governs.

### 3. Control Implementations

#### AC-17 Remote Access

Remote access extends the authorization boundary to authenticated users connecting from outside the corporate network.

Remote-access entitlements and VPN allow-lists are reviewed monthly by the network security team.

All remote sessions traverse the corporate VPN with enforced multi-factor authentication and are logged centrally.

#### AC-2 Account Management

Account management governs the full lifecycle of identities that can access the system, from provisioning through disablement.

Privileged, standard, and service accounts are reviewed quarterly by the ISSO to confirm continued need and least-privilege alignment.

Provisioning is initiated from an approved request and enforced through the enterprise identity provider; the ISSO is accountable for the control.

#### AC-6 Least Privilege

The principle of least privilege constrains each role to the minimum set of permissions required to

perform its function.

Least-privilege role assignments are recertified quarterly by the ISSO together with the system owner.

Role definitions are maintained in the identity provider and mapped to documented job functions.

### **AT-2 Literacy Training and Awareness**

Security literacy ensures that every individual with access understands their responsibilities and the threats relevant to their role.

Role-based security awareness training is delivered to all personnel quarterly, with completion tracked in the learning management system.

Curricula are tailored to general users, privileged users, and incident responders, and completion is a condition of continued access.

### **AU-6 Audit Record Review**

Audit review converts raw event data into actionable detections by surfacing anomalous and unauthorized behavior.

Audit logs are reviewed for anomalous and unauthorized activity weekly by the on-duty SOC analyst.

Events are aggregated into the SIEM and correlated against detection content aligned to the MITRE ATT&CK matrix.

### **PM-14 Testing, Training, and Monitoring**

A managed testing and training program measures and improves the effectiveness of the security capability over time.

The enterprise security testing and training program is evaluated for effectiveness annually.

Program metrics are reviewed by leadership and drive investment in tooling, staffing, and curriculum.

### **SI-4 System Monitoring**

System monitoring provides the detective controls that surface intrusions and policy violations in near-real time.

Security-monitoring detections and dashboards are reviewed monthly by the Security Operations Center.

Detections forward to an alerting pipeline that pages the on-call analyst, who triages within the documented window.

## **4. Supporting Controls**

### **PS-3 Personnel Screening**

Individuals are screened commensurate with the sensitivity of the information they will access prior to authorization, and re-screened in accordance with applicable requirements.

**SA-4 Acquisition Process**

Security requirements are incorporated into acquisition contracts so that delivered components meet the organization's protection needs.